

1. Database Design Overview

There will be **two main authentication contexts**:

- **Admin Portal (Owner Side)** – manages platform, vendors, subscriptions.
- **Vendor Portal (POS/E-commerce Side)** – manages store operations, products, and sales.

To maintain flexibility and centralized authentication, both can exist in a **shared users table** with roles and tenant references.

However, for cleaner isolation in MVP, you can also separate into two schemas or prefix tables (e.g., admin_users, vendor_users).

2. Admin Authentication Tables

Table: admin_users

Field Name	Type	Description
id	UUID / BIGINT (PK)	Unique identifier
full_name	VARCHAR(150)	Admin’s full name
email	VARCHAR(255), UNIQUE	Work email used for login
password_hash	TEXT	Encrypted password using Argon2id or b
role	ENUM('super_admin','support','billi ng')	Defines access level
is_email_verified	BOOLEAN (default FALSE)	Email verification status
email_verification_token	VARCHAR(255)	Token sent to verify email
email_token_expiry	DATETIME	Expiration of email token
two_factor_enabled	BOOLEAN	True if 2FA is activated
two_factor_secret	VARCHAR(255), NULL	Secret for TOTP (encrypted)
last_login_at	TIMESTAMP	Timestamp of last successful login
failed_login_attempts	INT (default 0)	For rate limiting/lockout
account_locked_until	DATETIME	Lockout expiration
status	ENUM('active','suspended')	Account status
created_at	TIMESTAMP	Date created
updated_at	TIMESTAMP	Date updated

Table: admin_sessions

Field Name	Type	Description
id	UUID (PK)	Unique session ID
admin_user_id	FK(admin_users.id)	Linked user
session_token	VARCHAR(255)	Encrypted session ID (JWT or random UU
ip_address	VARCHAR(45)	IP address used
user_agent	TEXT	Device/browser info
is_active	BOOLEAN	Active session flag
created_at	TIMESTAMP	Session start
expires_at	TIMESTAMP	Expiration date

Table: password_resets

(Shared for both admin and vendor users)

Field Name	Type	Description
id	UUID (PK)	Unique reset entry
user_type	ENUM('admin','vendor')	Identify which table it applies to
email	VARCHAR(255)	User email
reset_token	VARCHAR(255)	Token for password reset
expires_at	TIMESTAMP	Token expiration
used	BOOLEAN (default FALSE)	Whether the token was used
created_at	TIMESTAMP	Request timestamp

3. Vendor Authentication Tables

Table: vendors

Field Name	Type	Description
id	UUID (PK)	Vendor account identifier
business_name	VARCHAR(150)	Vendor’s business or store name
email	VARCHAR(255), UNIQUE	Used for account access

password_hash	TEXT	Encrypted password using Argon2 bcrypt
subscription_plan	VARCHAR(100)	Selected plan (e.g., Basic, Pro)
subscription_status	ENUM('active','trial','canceled','past_due')	Current subscription state
store_domain	VARCHAR(255), UNIQUE	Generated subdomain (e.g., myshop.vendora.site)
is_email_verified	BOOLEAN	Verification status
email_verification_token	VARCHAR(255)	Token for email confirmation
email_token_expiry	DATETIME	Expiration date of token
two_factor_enabled	BOOLEAN	2FA enabled flag
two_factor_secret	VARCHAR(255), NULL	Secret key for OTP
last_login_at	TIMESTAMP	Last successful login
failed_login_attempts	INT (default 0)	Login attempt count
account_locked_until	DATETIME	Lockout until time
status	ENUM('active','suspended','deleted')	Account state
created_at	TIMESTAMP	Creation date
updated_at	TIMESTAMP	Last update date

Table: vendor_sessions

Field Name	Type	Description
id	UUID (PK)	Unique session ID
vendor_id	FK(vendors.id)	Linked vendor
session_token	VARCHAR(255)	Secure token
ip_address	VARCHAR(45)	Logged IP
user_agent	TEXT	Device/browser info
is_active	BOOLEAN	Active flag
created_at	TIMESTAMP	Created time
expires_at	TIMESTAMP	Expiration

Table: subscriptions

(Connected to vendors and payment processors)

Field Name	Type	Description
id	UUID (PK)	Subscription ID
vendor_id	FK(vendors.id)	Linked vendor
provider	ENUM('stripe','paypal')	Payment provider
provider_subscription_id	VARCHAR(255)	Subscription ID from provider
plan_name	VARCHAR(100)	Subscription plan name
status	ENUM('active','trialing','canceled','past_due','incomplete')	Current state
current_period_start	TIMESTAMP	Billing cycle start
current_period_end	TIMESTAMP	Billing cycle end
cancel_at_period_end	BOOLEAN	Indicates scheduled cancellation
created_at	TIMESTAMP	Creation date
updated_at	TIMESTAMP	Last update

4. Shared Security & Validation Logic

Security Mechanism	Implementation Detail
Password Hashing	Argon2id (preferred) or bcrypt with cost ≥ 12
Session Tokens	Random UUIDs or JWT with rotation every login
Email Verification	Token stored in DB with 30–60 min expiry
Login Lockout	After 5 failed attempts, lock for 15 minutes
2FA (Optional)	TOTP (Google Authenticator) or email-based
SSL Enforcement	All communication over HTTPS
SameSite Cookies	HttpOnly , Secure , SameSite=Lax
Data Privacy	Passwords, 2FA secrets, and tokens must never be logged
Auditing	Track last_login_at and IP for every session

5. Relationships Summary

Relationship	Description
admin_users → admin_sessions	One-to-many (one admin can have multiple sessions)
vendors → vendor_sessions	One-to-many
vendors → subscriptions	One-to-one (active plan)
password_resets	Polymorphic table shared by both admin and vendor use

